

E-TİCARET UYGULAMASI

Yazılım Gereksinim ve Tasarım Dokümanı

(Software Requirements & Design Document)

Alan	Değer
Proje adı	E-Ticaret (Ongima)
Belge türü	Yazılım Gereksinim ve Tasarım Dokümanı (SRS/SDD)
Sürüm	1.0
Tarih	17 Temmuz 2026
Hazırlayan	Aslıhan Erturhan
Teknoloji	.NET 8 / ASP.NET Core Web API, Entity Framework Core 8, SQL Server, JWT, düz HTML/CSS/JavaScript
Durum	Geliştirme aşaması — çalışır durumda

Belge geçmişi

Sürüm	Tarih	Açıklama	Yazan
1.0	17.07.2026	İlk yayım. Mevcut kod tabanı esas alınarak hazırlandı.	A. Erturhan

Bu belge, uygulamanın kaynak kodu incelenerek hazırlanmıştır; içindeki gereksinimler, iş kuralları ve arayüz tanımları hâlihazırda gerçekleşmiş davranışı yansıtır.

İÇİNDEKİLER

1. GİRİŞ	4
1.1 Amaç	4
1.2 Kapsam	4
1.3 Tanımlar ve Kısaltmalar	4
1.4 Referanslar	4
1.5 Belgenin Yapısı	5
2. GENEL TANIM	6
2.1 Ürün Perspektifi	6
2.2 Ürün İşlevleri	6
2.3 Kullanıcı Sınıfları	6
2.4 İşletim Ortamı	6
2.5 Tasarım Kısıtları	7
2.6 Varsayımlar ve Bağımlılıklar	7
3. SİSTEM MİMARİSİ	8
3.1 Mimari Genel Bakış	8
3.2 Teknoloji Yığını ve Gerekçeleri	8
3.3 Sunucu Katmanları	9
3.4 İstemci Yapısı	9
3.5 İstek Yaşam Döngüsü	9
4. VERİ MODELİ	10
4.1 Varlık-İlişki (ER) Diyagramı	10
4.2 İlişkiler ve Silme Davranışları	10
4.3 Tablo Tanımları	11
4.4 Sipariş Durum Makinesi	13
5. FONKSİYONEL GEREKSİNİMLER	14
5.1 Kimlik Doğrulama ve Yetkilendirme	14
5.2 Ürün Kataloğu	14
5.3 İndirim Yönetimi	15
5.4 Sepet	15
5.5 Sipariş	15
5.6 Profil	16
5.7 Yönetim Paneli	16
5.8 Bildirim ve Denetim	16

6. İŞ KURALLARI	18
7. KULLANIM SENARYOLARI	20
8. KULLANICI ARAYÜZÜ	23
8.1 Ekran Listesi	23
8.2 Ekranlar Arası Akış	23
8.3 Yönetim Paneli Sekmeleri	23
8.4 Arayüz İlkeleri	24
9. API REFERANSI	25
9.1 Kimlik — /api/auth	25
9.2 Katalog — /api/products, /api/categories	25
9.3 Sepet ve Sipariş — /api/cart, /api/orders	25
9.4 Yönetim — /api/admin	26
9.5 Ortak Hata Yanıtları	26
10. FONKSİYONEL OLMAYAN GEREKSİNİMLER	27
10.1 Güvenlik	27
10.2 Başarım	27
10.3 Kullanılabilirlik	27
10.4 Sürdürülebilirlik	27
11. TEST VE DOĞRULAMA	29
11.1 Doğrulama Yöntemi	29
11.2 Kritik Test Senaryoları	29
EK-A: KURULUM VE ÇALIŞTIRMA	31
A.1 Gereksinimler	31
A.2 Sunucu Kurulumu	31
A.3 Sık Karşılaşılan Sorunlar	31
EK-B: YAPILANDIRMA	32
B.1 Sabitler	32

1. GİRİŞ

1.1 Amaç

Bu belgenin amacı, E-Ticaret uygulamasının işlevsel ve işlevsel olmayan gereksinimlerini, sistem mimarisini, veri modelini ve iş kurallarını eksiksiz biçimde tanımlamaktır. Belge; projeyi geliştirecek, sürdürecekt, test edecek veya değerlendirecek kişiler için tek başvuru kaynağı olacak şekilde yazılmıştır.

1.2 Kapsam

E-Ticaret (ürün adıyla *Ongima*), uçtan uca çalışan bir çevrimiçi satış uygulamasıdır. Sistem iki ana kullanıcı sınıfına hizmet eder: ürünleri inceleyip sipariş veren **müşteri** ve kataloğu, siparişleri ve kullanıcıları yöneten **yönetici**.

- Kapsam içi:** üyelik ve oturum yönetimi, ürün kataloğu ve kategori ağacı, arama/filtreleme/sıralama, süreli indirim yönetimi, stok rezervasyonlu sepet, teslimat bilgisiyle sipariş oluşturma, kalem bazında sipariş onayı, sipariş durum takibi ve iptali, e-posta bildirimi, yönetim paneli (sipariş/ürün/kategori/kullanıcı/log/analiz) ve denetim kaydı.
- Kapsam dışı:** gerçek ödeme altyapısı (sanal POS, 3D Secure), kargo firması entegrasyonu, fatura kesimi, çok dillilik, çok para birimi, ürün yorumları ve puanlama, şifre sıfırlama akışı.

Uygulama bir öğrenme projesi olarak geliştirilmiştir; bu nedenle ödeme ve kargo gibi dış servis bağımlılıkları bilinçli olarak kapsam dışında bırakılmış, iş mantığı ve güvenlik konularına odaklanılmıştır.

1.3 Tanımlar ve Kısaltmalar

Terim	Açıklama
API	Application Programming Interface — istemcinin sunucusuyla konuştuğu arayüz.
JWT	JSON Web Token — imzalı, sunucuda durum tutmayan kimlik jetonu.
Claim	JWT içindeki kimlik bilgisi alanı (kullanıcı adı, rol, kullanıcı no).
EF Core	Entity Framework Core — nesne-ilişkisel eşleme (ORM) katmanı.
Code-First	Veritabanı şemasının C# sınıflarından migration ile üretilmesi.
Migration	Şema değişikliğinin sürümlenebilir kod olarak tutulması.
DTO	Data Transfer Object — dış dünyaya açılan, entity'den ayrı veri taşıyıcı.
Entity	Veritabanı tablosuna karşılık gelen C# sınıfı.
Soft delete	Kaydı silmek yerine pasife çekme (<code>IsActive=false</code>).
Rezervasyon	Sepete eklenen ürünün stoktan geçici olarak ayrılması.
Efektif fiyat	İndirim aktifse indirimli fiyat, değilse liste fiyatı.
Kalem	Siparişin tek bir ürüne ait satırı (<code>OrderItem</code>).
Kısmi onay	Siparişin bazı kalemlerinin onaylanıp bazılarının reddedilmesi.
CORS	Tarayıcının farklı kaynaklara istek atmasını yöneten güvenlik kuralı.
Rate limit	Belirli sürede izin verilen istek sayısı üst sınırı.
UTC	Eşgüdümlü Evrensel Zaman — tüm tarihler bu ölçekte saklanır.

1.4 Referanslar

- **README.md** — projenin tanıtımı ve kurulum adımları.
- **GELISTIRME-GUNLUGU.md** — alınan kararların, karşılaşılan hataların ve öğrenilen kavramların kronolojik kaydı.
- **Swagger / OpenAPI** — uygulama geliştirme kipinde çalışırken /swagger adresinde yayımlanan, istek/yanıt gövdelerini içeren canlı API şeması.
- **Kaynak kod** — bu belgedeki tüm gereksinim ve kuralların birincil doğrulama kaynağı.

1.5 Belgenin Yapısı

2. bölüm sistemi genel hatlarıyla ve kullanıcı sınıflarıyla tanıtır. 3. bölüm mimariyi, 4. bölüm veri modelini açıklar. 5. bölüm numaralandırılmış fonksiyonel gereksinimleri (FR), 6. bölüm iş kurallarını (BR) listeler. 7. bölüm kullanım senaryolarını (UC), 8. bölüm ekranları, 9. bölüm API'yi, 10. bölüm işlevsel olmayan gereksinimleri (NFR), 11. bölüm test yaklaşımını içerir. Ekler kurulum ve yapılandırma bilgisini taşır.

2. GENEL TANIM

2.1 Ürün Perspektifi

Sistem, birbirinden bağımsız çalışan ve yalnızca HTTP/JSON üzerinden haberleşen iki parçadan oluşur: bir **ASP.NET Core Web API** (sunucu) ve **düz HTML/CSS/JavaScript** ile yazılmış, herhangi bir çatı (framework) kullanmayan bir **istemci**. Bu ayırım, ileride istemcinin mobil uygulamayla değiştirilebilmesine ya da API'nin başka bir istemciye hizmet vermesine olanak tanır. Sistem tek dış servise bağımlıdır: sipariş bildirim e-postalarını gönderen **EmailJS**.

2.2 Ürün İşlevleri

Modül	Başlıca işlevler
Kimlik	Kayıt, giriş, JWT üretimi, rol bazlı yetki, hesap engelleme
Katalog	Ürün listeleme, arama, kategori ağacı, fiyat aralığı, sıralama, ürün detayı, çoklu görsel
İndirim	Ürün bazında, kategori bazında ve toplu süreli indirim
Sepet	Ekleme, adet güncelleme, satır silme, 30 dakikalık stok rezervasyonu
Sipariş	Teslimat bilgisiyle sipariş oluşturma, geçmiş, durum takibi, 1 saat içinde iptal
Yönetim	Kalem bazında onay/red, durum ilerletme, ürün/kategori/kullanıcı yönetimi, loglar, analiz
Bildirim	Sipariş durumu değişikçe müşteriye e-posta
Denetim	Değişiklik yapan tüm isteklerin otomatik kaydı

2.3 Kullanıcı Sınıfları

Sınıf	Tanım	Yetkiler
Ziyaretçi	Giriş yapmamış kullanıcı.	Vitrini ve ürün detayını görüntüler. Sepete ekleyemez, sipariş veremez.
Müşteri (Customer)	Kayıtlı, giriş yapmış son kullanıcı. Kayıt olan herkes varsayılan olarak bu rolü alır.	Sepet işlemleri, sipariş oluşturma, kendi sipariş geçmişi ve ürün alım geçmişi, 1 saat içinde iptal, profil güncelleme.
Yönetici (Admin)	Katalogu ve siparişleri yöneten personel. Rol yalnızca veritabanından verilir.	Müşterinin tüm yetkileri + yönetim panelinin tamamı: sipariş kararı, ürün/kategori/kullanıcı yönetimi, indirim, log ve analiz.

Yönetici rolü arayüzden verilemez; kasıtlı bir güvenlik kararıdır. İlk yönetici, veritabanında Ro leId alanı elle güncellenerek oluşturulur (bkz. EK-A).

2.4 İşletim Ortamı

Bileşen	Gereksinim
Sunucu çalışma zamanı	.NET 8 SDK / ASP.NET Core
Veritabanı	Microsoft SQL Server (Windows Authentication ile erişim varsayılır)
İstemci	ES2020 destekli güncel tarayıcı (Chrome, Edge, Firefox)
Sunucu adresi	http://localhost:5113 (geliştirme)
İstemci sunumu	5500/5501 portunda statik dosya sunucusu
Dış servis	EmailJS REST API (sipariş bildirimi)

2.5 Tasarım Kısıtları

- İstemci tarafında **hiçbir çatı veya derleme adımı kullanılmaz**; sayfalar düz HTML ve tarayıcıya doğrudan yüklenen JavaScript dosyalarından oluşur.
- Sunucu **durum tutmaz** (stateless): oturum sunucu belleğinde değil, imzalı JWT içinde taşınır.
- Tüm tarih/saat değerleri veritabanında ve JSON'da **UTC** olarak tutulur; yerel saate çevirme görüntüleme katmanının işidir.
- Parasal alanlar `decimal(18,2)` hassasiyetiyle saklanır; kayan noktalı tip kullanılmaz.
- Gizli bilgiler (bağlantı dizesi, JWT anahtarı, EmailJS anahtarları) kaynak koda yazılmaz; **User Secrets** ile yönetilir.
- Arayüz metinleri ve kod yorumları Türkçedir.

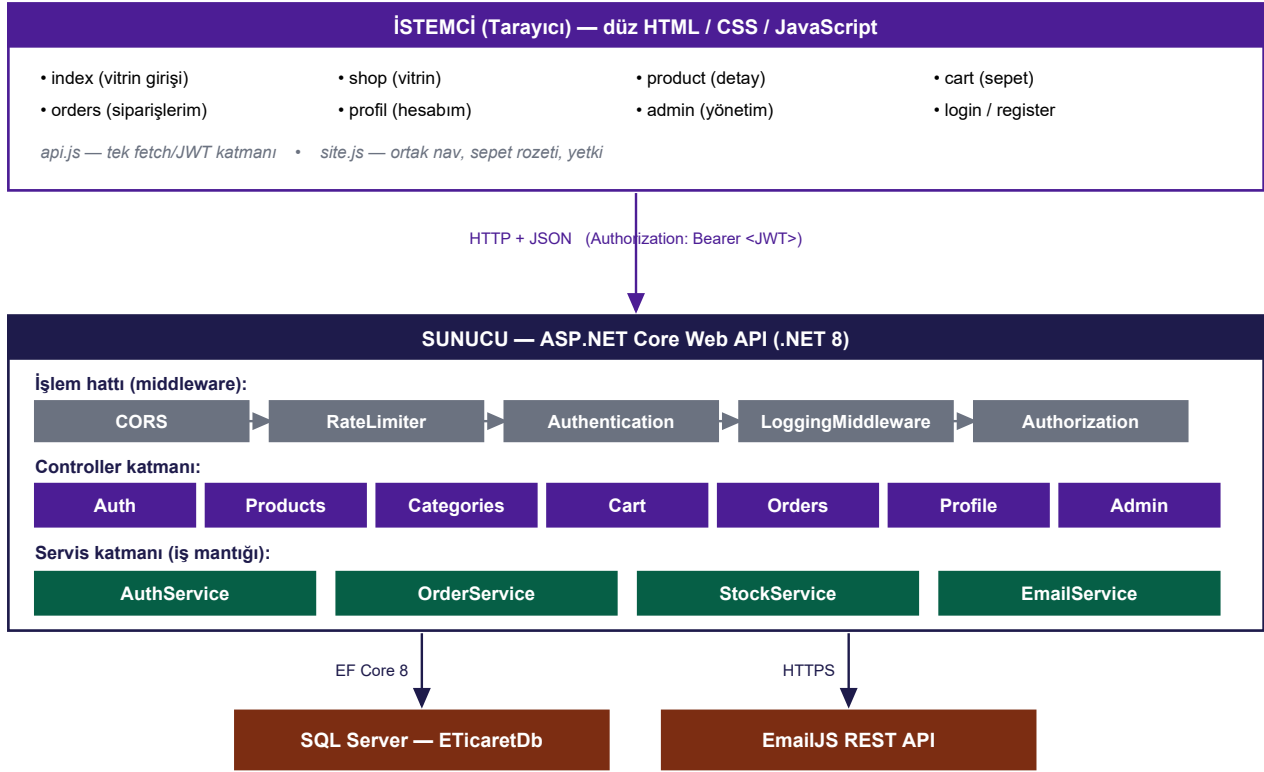
2.6 Varsayımlar ve Bağımlılıklar

- Ödeme alınmaz; sipariş, yöneticinin onayıyla geçerli sayılır.
- Stok yönetimi tek depo üzerinden yürür; varyant (beden, renk) kavramı yoktur.
- E-posta gönderimi EmailJS hesabının kotasına ve erişilebilirliğine bağlıdır. Servis yanıt vermezse **sipariş akışı kesilmez**; hata loglanır ve işlem sürer.
- Kullanıcının e-posta adresi bildirimlerin tek kanalıdır; bu nedenle kayıta zorunludur ve benzersizdir.

3. SİSTEM MİMARİSİ

3.1 Mimari Genel Bakış

Sistem, istemci ve sunucunun tamamen ayrıldığı katmanlı bir mimari kullanır. İstemci yalnızca HTTP/JSON ile konuşur ve kimliğini her istekte `Authorization` başlığındaki JWT ile bildirir. Sunucu tarafında istek; CORS, hız sınırlama, kimlik doğrulama, loglama ve yetkilendirme adımlarından geçtikten sonra ilgili denetleyiciye (controller) ulaşır.



3.2 Teknoloji Yığını ve Gerekçeleri

Katman	Seçim	Gerekçe
Sunucu	.NET 8 / ASP.NET Core Web API	Güçlü tiplendirme, olgun kimlik doğrulama altyapısı, yerleşik bağımlılık enjeksiyonu.
ORM	Entity Framework Core 8 (Code-First)	Şema, C# sınıflarından migration ile üretilir; şema değişiklikleri sürümlenir.
Veritabanı	SQL Server	İlişkisel bütünlük, kısıtlar ve işlem (transaction) desteği.
Kimlik	JWT (HMAC-SHA256)	Sunucuda durum tutmaz; yatay ölçeklemeye ve farklı istemcilere uygundur.
Parola	ASP.NET Core PasswordHasher	Tuzlu (salted) ve yinelenmeli özet; parola asla düz metin saklanmaz.
İstemci	Düz HTML / CSS / JavaScript	Öğrenme amacı: çatı soyutlaması olmadan temel kavramların doğrudan görülmesi.
Bildirim	EmailJS (sunucu tarafından çağrılır)	Kendi SMTP altyapısını kurmadan e-posta gönderimi.

3.3 Sunucu Katmanları

Katman	Sorumluluk	Örnek
Controller	HTTP'yi karşılar, yetkiyi doğrular, DTO'ya çevirir. İş mantığı barındırmaz.	OrdersController
Service	Gerçek iş mantığı ve kurallar. Birden çok yerden kullanılan kararların tek adresi.	OrderService, StockService
Middleware	Tüm isteklere uygulanan çapraz kesen işler.	LoggingMiddleware
Data	EF Core bağlamı, ilişki ve hassasiyet yapılandırması.	AppDbContext
Models	Entity (tablo karşılığı) ve DTO (dışa açılan veri) ayrımı.	Product / ProductDto

Tasarım kuralı: gerçek iş mantığı içermeyen basit CRUD işlemlerinde ayrı bir servis katmanı oluşturulmaz, denetleyici doğrudan veri bağlamını kullanır (örn. kategoriler). Servis katmanı yalnızca stok, sipariş, kimlik ve bildirim gibi kural yoğun alanlarda vardır.

3.4 İstemci Yapısı

Her HTML sayfasının kendi JavaScript dosyası vardır; iki dosya ise tüm sayfalarca paylaşılır:

- `api.js` — API taban adresi ve `apiGet/apiPost/apiPut/apiDelete` yardımcıları. JWT başlığının eklenmesi ve hata çevirisi **tek yerde** toplanır.
- `site.js` — ortak gezinme çubuğu, sepet rozeti, sepete ekleme, HTML kaçışlama (`escapeHtml`) ve JWT çözerek rol/oturum okuma (`authInfo`, `requireAuth`).

Rol bilgisi ayrı bir `localStorage` değerinden değil, **imzalı JWT'nin içinden** okunur. Aksi hâlde tarayıcı konsolundan rol değeri değiştirilerek yönetim paneline erişilebilirdi.

3.5 İstek Yaşam Döngüsü

Bir siparişin onaylanması örneğinde akış şöyledir:

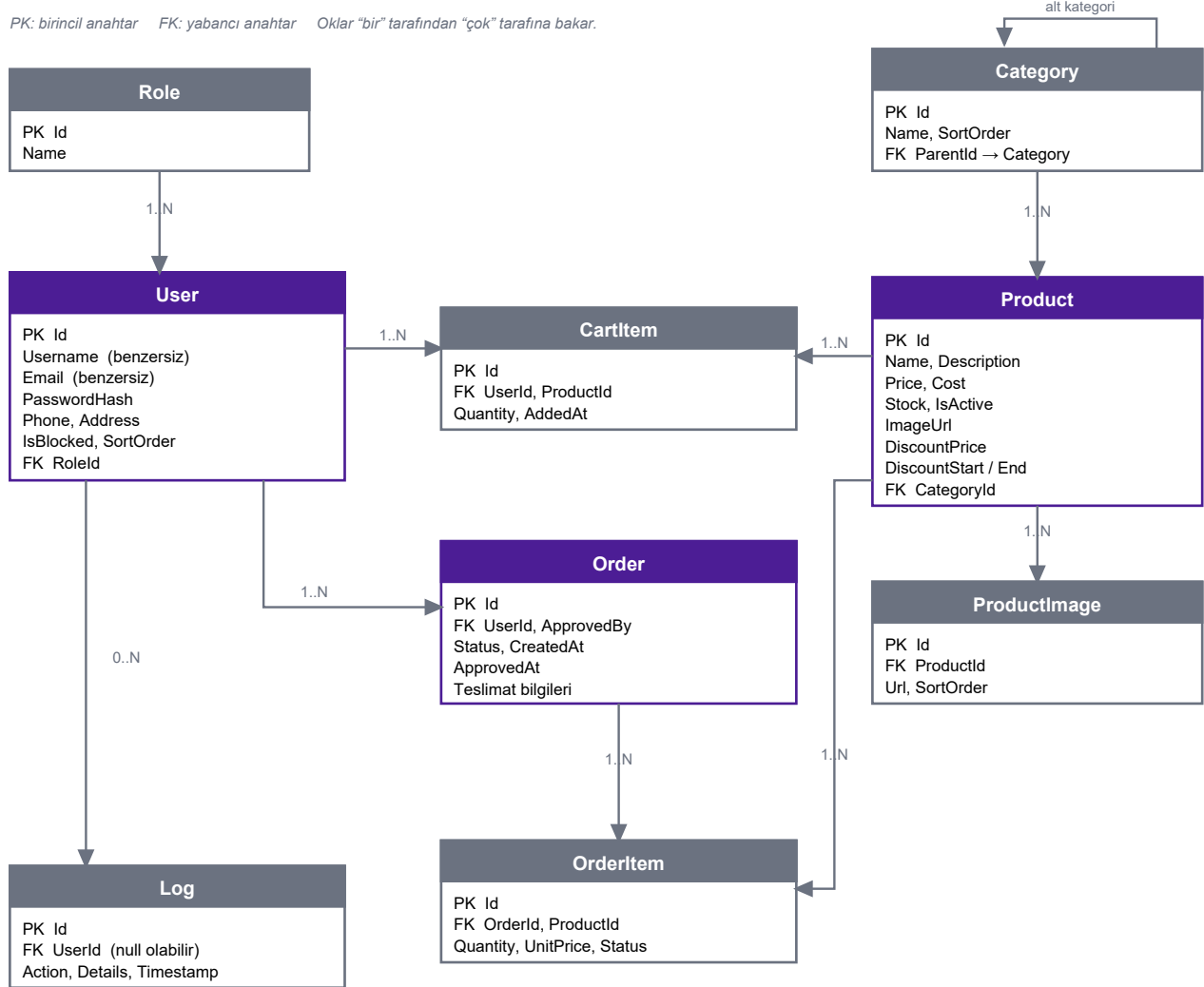
#	Adım
1	İstemci <code>PUT /api/admin/orders/12/approve</code> isteğini JWT ile gönderir.
2	CORS kuralı kaynağı denetler.
3	Kimlik doğrulama JWT imzasını ve süresini doğrular; ardından <code>OnTokenValidated</code> olayında kullanıcının hâlâ engelli olmadığı veritabanından teyit edilir.
4	Yetkilendirme Admin rolünü arar.
5	<code>AdminController</code> isteği <code>OrderService.ApproveOrderAsync</code> 'e devreder.
6	Servis stok yeterliliğini denetler, kalemleri onaylar, <code>Product.Stock</code> değerini düşürür ve kaydeder.
7	<code>EmailService</code> müşteriye bilgilendirme e-postası gönderir; başarısız olursa hata loglanır, işlem geri alınmaz.
8	<code>LoggingMiddleware</code> işlemi "Sipariş onaylandı" olarak Logs tablosuna yazar.

4. VERİ MODELİ

4.1 Varlık-İlişki (ER) Diyagramı

Veri modeli dokuz varlıktan oluşur. Şema, EF Core Code-First yaklaşımıyla C# sınıflarından migration'lar aracılığıyla üretilir. Solda kimlik, sağda katalog, ortada bu ikisini birleştiren işlem varlıkları yer alır.

PK: birincil anahtar FK: yabancı anahtar Oklar "bir" tarafından "çok" tarafına bakar.



4.2 İlişkiler ve Silme Davranışları

İlişki	Tür	Silme davranışı	Gerekçe
Role → User	1..N	Varsayılan	Her kullanıcının tam bir rolü vardır.
Category → Product	1..N	Varsayılan	Her ürün bir kategoriye bağlıdır.
Category → Category	1..N	Restrict	Alt kategorisi olan üst kategori silinemez; ağaç bozulmaz.
Product → ProductImage	1..N	Cascade	Ürün silinirse ek görselleri de gitmelidir; yetim kayıt kalmaz.
User → CartItem	1..N	Varsayılan	Sepet satırı kullanıcıya aittir.
Product → CartItem	1..N	Varsayılan	Sepet satırı bir ürüne işaret eder.
User → Order	1..N	Restrict	Siparişi olan kullanıcı silinemez; sipariş geçmişi sahipsiz kalmaz.

İlişki	Tür	Silme davranışı	Gerekçe
User → Order (ApprovedBy)	1..N	Restrict	Onaylayan yönetici kaydı korunur. user'a ikinci bağlantıdır; belirsizlik Fluent API ile giderilir.
Order → OrderItem	1..N	Varsayılan	Sipariş kalemlerden oluşur.
Product → OrderItem	1..N	Varsayılan	Kalem bir ürüne işaret eder.
User → Log	0..N	Varsayılan	UserId boş olabilir (kimliksiz istek).

Neden Restrict? Bir kullanıcı silindiğinde siparişlerinin de silinmesi (Cascade), ticari kaydı yok etmek anlamına gelir. Bunun yerine silme engellenir ve yönetici kullanıcıyı **engelleme** seçeneğine yönlendirilir.

4.3 Tablo Tanımları

Users

Alan	Tip	Kısıt / Açıklama
Id	int	PK, otomatik artan
Username	nvarchar	Benzersiz, en az 3 karakter
Email	nvarchar?	Benzersiz; kayıta zorunlu, bildirimlerin tek kanalı
Phone, Address	nvarchar?	İsteğe bağlı; teslimat formuna ön değer olur
PasswordHash	nvarchar	Tuzlu özet; JSON'a asla yazılmaz ([JsonIgnore])
CreatedAt	datetime2	UTC
CreatedBy	nvarchar?	Kayıdı oluşturan (yönetici eklediyse)
SortOrder	int	Yönetim panelinde elle sıralama
IsBlocked	bit	true ise giriş yapamaz ve mevcut jetonu geçersizdir
RoleId	int	FK → Roles

Products

Alan	Tip	Kısıt / Açıklama
Id	int	PK
Name	nvarchar	Ürün adı
Description	nvarchar?	Açıklama
Price	decimal(18,2)	Liste fiyatı
Cost	decimal(18,2)?	Maliyet; yalnızca yöneticiye gösterilir, kâr hesabında kullanılır
Stock	int	Depodaki fiziksel adet; yalnızca onayda düşer
ImageUrl	nvarchar?	Ana görsel
IsActive	bit	Soft delete: false ise vitrinde görünmez
CategoryId	int	FK → Categories
DiscountPrice	decimal(18,2)?	İndirimli fiyat; Price'tan küçük olmalıdır
DiscountStart / DiscountEnd	datetime2?	İndirim penceresi; null ise sınırsız uç

Orders

Alan	Tip	Kısıt / Açıklama
Id	int	PK
UserId	int	FK → Users (Restrict)
Status	int (enum)	Pending=0, Approved=1, Rejected=2, Shipped=3, Delivered=4, Cancelled=5
CreatedAt	datetime2	UTC; iptal süresi bu andan işler
ApprovedAt	datetime2?	Karar anı
ApprovedBy	int?	FK → Users; kararı veren yönetici
RecipientName, Phone, City, District, Address	nvarchar?	Sipariş anındaki teslimat bilgisinin anlık görüntüsü ; kullanıcı profilini sonradan değiştirse bile sipariş sabit kalır

OrderItems

Alan	Tip	Kısıt / Açıklama
Id	int	PK
OrderId	int	FK → Orders
ProductId	int	FK → Products
Quantity	int	Adet
UnitPrice	decimal(18,2)	Sipariş anındaki efektif fiyatın anlık görüntüsü. Ürünün fiyatı sonradan değişse bile sipariş değişmez.
Status	int (enum)	Kalem bazında karar: Pending / Approved / Rejected

CartItems

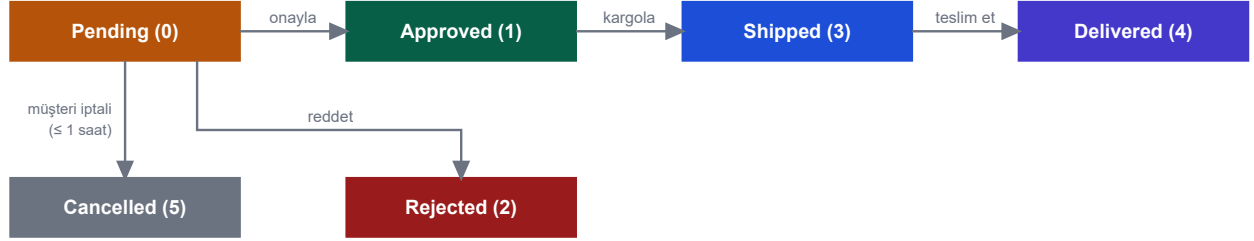
Alan	Tip	Kısıt / Açıklama
Id	int	PK
UserId, ProductId	int	FK → Users / Products
Quantity	int	Adet
AddedAt	datetime2	Rezervasyonun başladığı an; adet artırılırsa yenilenir. 30 dakika sonra rezervasyon düşer (BR-4)

Categories / ProductImages / Roles / Logs

Tablo	Alanlar
Categories	Id (PK), Name, SortOrder, ParentId (FK → Categories, null ise ana kategori)
ProductImages	Id (PK), ProductId (FK, Cascade), Url, SortOrder (slider sırası)
Roles	Id (PK), Name — 'Admin' ve 'Customer'. Rol koda gömülmez, tabloda tutulur.
Logs	Id (PK), UserId (FK, null olabilir), Action, Details, Timestamp

4.4 Sipariş Durum Makinesi

Sipariş ve kalem durumları aynı `orderStatus` sayımını (enum) kullanır; kalemler için yalnızca Pending, Approved ve Rejected anlamlıdır. Geçişler sunucuda zorlanır:



Onay/red yalnızca Pending durumundan verilebilir. Kargola ve teslim et yalnızca gösterilen sırayla ilerler; başka geçiş 'Geçersiz durum geçişi' hatası verir.

Geçiş	Koşul	Yan etki
Pending → Approved	En az bir kalem onaylanmış ve stok yeterli	Onaylanan kalemlerin adedi <code>Product.Stock</code> 'tan düşer; bilgilendirme e-postası
Pending → Rejected	Hiçbir kalem onaylanmamış	Stok değişmez; e-posta
Pending → Cancelled	Müşteri talebi, sipariş anından itibaren ≤ 1 saat	Stok değişmez (henüz düşmemiştir)
Approved → Shipped	Yönetici işlemi	E-posta
Shipped → Delivered	Yönetici işlemi	E-posta
Silme	Yalnızca Rejected / Delivered / Cancelled	Kayıt tamamen silinir

Kısmi onay: yönetici kalemleri tek tek seçebilir. Seçilmeyenler reddedilir. En az bir kalem onaylıysa siparişin genel durumu Approved, hiçbir onaylı değilse Rejected olur.

5. FONKSİYONEL GEREKSİNİMLER

Gereksinimler modüllere ayrılmış ve **FR-** ön ekiyle numaralandırılmıştır. Öncelik sütunu: **Z** = zorunlu (sistem onsuz çalışmaz), **Y** = yüksek, **O** = orta. Tüm gereksinimler mevcut kodda gerçekleşmiştir.

5.1 Kimlik Doğrulama ve Yetkilendirme

No	Gereksinim	Aktör	Ö.
FR-1.1	Ziyaretçi kullanıcı adı, e-posta ve şifreyle kayıt olabilmelidir. Kullanıcı adı en az 3, şifre en az 6 karakter olmalıdır.	Ziyaretçi	Z
FR-1.2	Kullanıcı adı ve e-posta sistemde benzersiz olmalıdır; tekrar eden kayıt anlaşılır bir hatayla reddedilmelidir.	Sistem	Z
FR-1.3	Kayıt olan her kullanıcı varsayılan olarak Customer rolünü almalıdır.	Sistem	Z
FR-1.4	Şifre veritabanında yalnızca tuzlanmış özet olarak saklanmalı, hiçbir yanıtta yer almamalıdır.	Sistem	Z
FR-1.5	Kullanıcı, kullanıcı adı ve şifresiyle giriş yaptığında sistem 120 dakika geçerli, kullanıcı adı/rol/kullanıcı no taşıyan imzalı bir JWT üretmelidir.	Müşteri, Yönetici	Z
FR-1.6	Korumalı uç noktalara erişim geçerli JWT gerektirmeli; yönetim uç noktaları ayrıca Admin rolü aramalıdır.	Sistem	Z
FR-1.7	Engellenmiş kullanıcı giriş yapamamalı; daha önce alınmış jetonu da geçersiz sayılmalıdır (her istekte veritabanından denetlenir).	Sistem	Y
FR-1.8	Giriş ve kayıt uçları IP başına dakikada 30 istekle sınırlanmalı, aşımında 429 dönmelidir.	Sistem	Y
FR-1.9	Başarılı giriş, başarısız giriş denemesi, engelli hesap denemesi ve kayıt olayları loglanmalıdır.	Sistem	O
FR-1.10	Jetonun süresi dolduğunda istemci kullanıcıyı giriş sayfasına yönlendirmelidir.	İstemci	O

5.2 Ürün Kataloğu

No	Gereksinim	Aktör	Ö.
FR-2.1	Ziyaretçi giriş yapmadan aktif ürünleri listeleyebilmeli ve detayını görebilmelidir.	Ziyaretçi	Z
FR-2.2	Pasif (soft-delete edilmiş) ürünler vitrinde görünmemeli; yalnızca yönetici bunları listeleyebilmelidir.	Sistem	Z
FR-2.3	Ürünler ada göre aranabilmelidir.	Ziyaretçi	Y
FR-2.4	Ürünler kategoriye ve fiyat aralığına göre süzulebilmeli, fiyata göre sıralanabilmelidir.	Ziyaretçi	Y
FR-2.5	Kategoriler iki düzeyli olmalı (üst kategori › alt kategori) ve ürün detayında tıklanabilir bir iz olarak gösterilmelidir.	Ziyaretçi	O
FR-2.6	Ürün detayında ana görsel ve ek görseller bir slider içinde sırayla gezilebilmelidir.	Ziyaretçi	O
FR-2.7	Müşteriye stok sayısı gösterilmemeli, yalnızca “stokta var / yok” bilgisi verilmelidir. Stok sayısı, maliyet ve indirim planı yalnızca yöneticiye döndürülmelidir.	Sistem	Z
FR-2.8	“Stokta var” bilgisi, başkalarının aktif sepet rezervasyonları ve onay bekleyen siparişleri düşüldükten sonra hesaplanmalıdır.	Sistem	Y
FR-2.9	Yönetici ürün ekleyebilmeli, güncelleyebilmeli, stok girebilmeli ve ürünü pasife alıp yeniden aktifleştirebilmelidir.	Yönetici	Z

No	Gereksinim	Aktör	Ö.
FR-2.10	Aynı adda pasif bir ürün varken yeni ürün eklenirse, yeni kayıt oluşturmak yerine mevcut kayıt canlandırılmalıdır.	Sistem	O

5.3 İndirim Yönetimi

No	Gereksinim	Aktör	Ö.
FR-3.1	Yönetici bir ürüne indirimli fiyat ve isteğe bağlı başlangıç/bitiş tarihi tanımlayabilmelidir. Tarih boş bırakılırsa indirim o uçta sınırsızdır.	Yönetici	Y
FR-3.2	İndirim yalnızca indirimli fiyat liste fiyatından küçükse ve içinde bulunulan an tarih aralığındaysa aktif sayılmalıdır.	Sistem	Z
FR-3.3	Yönetici bir kategorinin tüm ürünlerine tek işlemde indirim uygulayabilmelidir.	Yönetici	O
FR-3.4	Yönetici tabloda seçtiği ürünlere toplu indirim uygulayabilmeli veya indirimi kaldırabilmelidir.	Yönetici	O
FR-3.5	Tüm indirim işlemleri, kimin neye ne uyguladığı ayrıntısıyla loglanmalıdır.	Sistem	O
FR-3.6	Vitrinde indirimli ürünlerde eski fiyat üstü çizili, yeni fiyat vurgulu gösterilmelidir.	İstemci	O

5.4 Sepet

No	Gereksinim	Aktör	Ö.
FR-4.1	Yalnızca giriş yapmış kullanıcı sepete ürün ekleyebilmelidir.	Müşteri	Z
FR-4.2	Sepete ekleme, ürünü stoktan 30 dakikalığına rezerve etmelidir.	Sistem	Z
FR-4.3	Adet artırıldığında rezervasyon süresi yeniden başlamalıdır.	Sistem	O
FR-4.4	Kullanıcının kendi rezervasyonu, kendi müsaitlik hesabında “dolmuş” sayılmamalıdır.	Sistem	Y
FR-4.5	Müsait adedin üzerinde sepete ekleme reddedilmeli, kalan adet mesajda belirtilmelidir.	Sistem	Y
FR-4.6	Kullanıcı sepetteki adedi güncelleyebilmeli ve satırı silebilmelidir.	Müşteri	Z
FR-4.7	Sepeteki ürün sayısı tüm sayfalarda bir rozetle gösterilmelidir.	İstemci	O

5.5 Sipariş

No	Gereksinim	Aktör	Ö.
FR-5.1	Sipariş oluşturmak için alıcı adı, telefon, il, ilçe ve açık adres zorunlu olmalıdır.	Müşteri	Z
FR-5.2	Boş sepetle sipariş oluşturulamamalıdır.	Sistem	Z
FR-5.3	Sipariş oluşturulurken her kalem için stok müsaitliği yeniden doğrulanmalıdır.	Sistem	Z
FR-5.4	Kalem birim fiyatı, sipariş anındaki efektif fiyattan (indirim aktifse indirimli fiyat) dondurulmalıdır.	Sistem	Z
FR-5.5	Sipariş oluşunca sepet boşaltılmalı ve sipariş “Bekliyor” durumunda doğmalıdır.	Sistem	Z
FR-5.6	Teslimat bilgisi sipariş üzerine kopyalanmalı; kullanıcı profilini sonradan değiştirse bile eski sipariş değişmemelidir.	Sistem	Y
FR-5.7	Müşteri kendi sipariş geçmişini, durumunu ve teslimat bilgisini görebilmelidir.	Müşteri	Z
FR-5.8	Müşteri siparişini yalnızca “Bekliyor” durumundayken ve verilişinden sonraki 1 saat içinde iptal edebilmelidir. Kural sunucuda zorlanmalıdır.	Müşteri	Y

No	Gereksinim	Aktör	Ö.
FR-5.9	Müşteri, ürün detay sayfasında yalnızca kendi alım geçmişini (sipariş sayısı, adet, en düşük ödediği fiyat, son alış tarihi) görebilmelidir.	Müşteri	O

5.6 Profil

No	Gereksinim	Aktör	Ö.
FR-6.1	Kullanıcı kendi ad, e-posta, telefon ve adres bilgisini görüntüleyip güncelleyebilmelidir.	Müşteri	Y
FR-6.2	E-posta değişikliği biçim ve benzersizlik denetiminden geçmeli ve loglanmalıdır.	Sistem	O
FR-6.3	E-postası olmayan kullanıcı, bildirim alamayacağı konusunda uyarılmalıdır.	İstemci	O

5.7 Yönetim Paneli

No	Gereksinim	Aktör	Ö.
FR-7.1	Yönetici tüm siparişleri, müşteri ve teslimat bilgisiyle listeleyebilmelidir.	Yönetici	Z
FR-7.2	Yönetici siparişin tamamını onaylayabilmeli, reddedebilmeli veya kalemleri tek tek seçerek kısmi karar verebilmelidir.	Yönetici	Z
FR-7.3	Onayda stok yetersizse işlem, hangi üründe ne kadar eksik olduğu belirtilerek reddedilmelidir.	Sistem	Z
FR-7.4	Yönetici siparişi Kargoda ve Teslim Edildi durumlarına yalnızca geçerli sırayla ilerletebilmelidir.	Yönetici	Y
FR-7.5	Yalnızca sonuçlanmış (reddedilmiş, teslim edilmiş, iptal edilmiş) siparişler silinebilmelidir.	Sistem	O
FR-7.6	Yönetici kategori ekleyip güncelleyebilmeli, sıralayabilmelidir; alt kategorisi olan kategori silinememelidir.	Yönetici	Y
FR-7.7	Yönetici kullanıcı ekleyebilmeli, güncelleyebilmeli, engelleyebilmeli ve silebilmelidir. Siparişi olan kullanıcı silinememeli, bunun yerine engellenmesi önerilmelidir.	Yönetici	Y
FR-7.8	Yönetici bir ürüne tıklayarak o ürünün tüm sipariş hareketlerini (kim, hangi sipariş, ne zaman, kaç adet, hangi fiyattan) görebilmelidir.	Yönetici	O
FR-7.9	Panel; toplam ciro, kâr, en çok satan ürün, kategori bazında ciro ve ürün bazında satış dökmü sunulmalıdır. Yalnızca onaylanmış kalemler gerçek satış sayılmalıdır.	Yönetici	Y
FR-7.10	Panel yeni sipariş geldiğini periyodik yoklamayla fark edip rozetle bildirmelidir.	İstemci	O
FR-7.11	Yönetici tüm denetim kayıtlarını görüntüleyebilmelidir.	Yönetici	O

5.8 Bildirim ve Denetim

No	Gereksinim	Aktör	Ö.
FR-8.1	Sipariş oluşturulduğunda, onaylandığında/reddedildiğinde, kargoya verildiğinde ve teslim edildiğinde müşteriye e-posta gönderilmelidir.	Sistem	Y
FR-8.2	E-posta sunucudan gönderilmelidir; alıcı adresi sipariş sahibinin kaydından okunmalı, istemciden alınmamalıdır.	Sistem	Z
FR-8.3	E-posta gönderilemezse sipariş işlemi geri alınmamalı, hata loglanmalıdır.	Sistem	Y
FR-8.4	E-postadaki tarihler Türkiye saatine çevrilmiş olmalıdır.	Sistem	O

No	Gereksinim	Aktör	Ö.
FR-8.5	Veriyi değiştiren tüm başarılı istekler (GET hariç), kullanıcı ve okunabilir işlem adıyla otomatik loglanmalıdır.	Sistem	Y

6. İŞ KURALLARI

İş kuralları, gereksinimlerin arkasındaki değişmez mantığı tanımlar. Her biri sunucuda zorlanır; istemcideki karşılığı (buton gizleme vb.) yalnızca kullanıcıyı yönlendirmek içindir, güvenlik sınırı değildir.

No	Kural	Gerekçe
BR-1	Stok yalnızca onayda düşer. Sipariş oluşturmak veya sepete eklemek <code>Product.Stock</code> değerini değiştirmez.	Depodaki fiziksel adet ile satış vaadi ayrı kavramlardır; onaylanmamış sipariş henüz satış değildir.
BR-2	Müsait adet = Stok – başkalarının aktif sepet rezervasyonları – onay bekleyen sipariş adetleri.	Depoda durması satılabilir olduğu anlamına gelmez; o adetler üzerinde başkalarının hakkı olabilir.
BR-3	Onaylanmış kalemler müsaitlik hesabında ikinci kez düşülmez.	Onaylanan adet zaten Stok'tan düşmüştür; tekrar sayılırsa stok iki kat eksik görünür.
BR-4	Sepet rezervasyonu 30 dakika sürer. Süre dolunca ürün sepette kalır ama stoğu kilitlemez.	Terk edilmiş bir sepetin stoğu süresiz kilitlenmesi, satılabilir malı ölü stoğa çevirir.
BR-5	Kullanıcının kendi rezervasyonu, kendisine karşı "dolu" sayılmaz.	Aksi hâlde sepetinde 1 adet olan kullanıcı adedi 2'ye çıkarmak isterken kendi rezervasyonuna takılırdı.
BR-6	Kullanıcının kendi bekleyen siparişi ise stoğu tutar.	İki kez sipariş verip ikisinin birden onaylanmasını bekleyemez.
BR-7	Efektif fiyat: indirimli fiyat tanımlıysa, liste fiyatından küçükse ve içinde bulunulan an tarih aralığındaysa indirimli fiyat; aksi hâlde liste fiyatı.	İndirimin üç koşulu da sağlanmadan uygulanması, planlanmış kampanyanın erken başlaması demektir.
BR-8	Kalem birim fiyatı sipariş anında dondurulur .	Ürünün fiyatı sonradan değişse bile müşterinin ödediği tutar değişmemelidir.
BR-9	Teslimat bilgisi sipariş üzerine kopyalanır , kullanıcıdan referansla okunmaz.	Kullanıcı adresini sonradan değiştirdiğinde geçmiş siparişin nereye gittiği değişmemelidir.
BR-10	Sipariş yalnızca Bekliyor durumundayken ve verilışinden sonraki 1 saat içinde iptal edilebilir.	Onaylanıp hazırlanmaya başlanmış sipariş geri alınamaz. Süre kuralı sunucuda uygulanır; istek doğrudan API'ye de atılabilir.
BR-11	Kısmi onay: en az bir kalem onaylıysa sipariş Approved, hiçbiri onaylı değilse Rejected olur.	Yönetici stoğu yeten kalemleri gönderip yetmeyi reddedebilmelidir.
BR-12	Durum geçişleri yalnızca Approved → Shipped → Delivered sırasıyla ilerler; onay/red yalnızca Pending'den verilir.	Teslim edilmiş siparişin "kargolandı" olması veya işlenmiş siparişin yeniden onaylanması tutarsızlıktır.
BR-13	Yalnızca sonuçlanmış (Rejected / Delivered / Cancelled) siparişler silinebilir.	İşlem görmekte olan siparişin silinmesi, müşterinin takip edemeyeceği bir kayıp yaratır.
BR-14	Ürünler silinmez, pasife alınır (soft delete). Aynı adda pasif ürün varsa yeniden eklemede o kayıt canlandırılır.	Geçmiş siparişlerin işaret ettiği ürün kaybolmamalıdır.
BR-15	Alt kategorisi olan kategori silinemez (Restrict).	Kategori ağacının kırılmasını ve yetim kayıt oluşmasını önler.
BR-16	Siparişi olan kullanıcı silinemez (Restrict); engellenebilir.	Ticari kayıt korunmalıdır; engelleme, silmenin güvenli alternatifidir.
BR-17	Engellenen kullanıcının mevcut jetonu da geçersizdir; her istekte veritabanından denetlenir.	JWT sunucuda durum tutmaz; yalnızca girişte denetlemek, zaten giriş yapmış kullanıcının engellemeyi delmesine izin verirdi.

No	Kural	Gerekçe
BR-18	Stok sayısı, maliyet ve indirim planı müşteriye hiç gönderilmez ; müşteri yalnızca “stokta var/yok” görür.	Alanı gizlemek yetmez — veri yanıtta varsa tarayıcı konsolundan okunabilir.
BR-19	Müşteri, ürün detayında yalnızca kendi alım geçmişini görür.	Ürünün tüm hareketlerini göstermek, diğer müşterilerin ne alıp ne ödediğini ifşa ederdi.
BR-20	Analiz rakamlarında yalnızca onaylanmış kalemler gerçek satış sayılır.	Reddedilen veya bekleyen kalemin ciroya yazılması geliri olduğundan yüksek gösterir.
BR-21	Kâr = efektif satış fiyatı – maliyet.	İndirimli satılan üründe kârın liste fiyatından hesaplanması yanıltıcı olur.
BR-22	Tüm tarihler UTC saklanır ve JSON'a “Z” ekiyle yazılır.	Aksi hâlde tarayıcı, belirsiz tarihi yerel saat sanıp kaydırır.
BR-23	E-posta sunucudan gönderilir; alıcı adres sipariş sahibinin kaydından okunur.	İstemciden gönderilseydi konsolu açan herkes sistemin kotasından istediği adrese posta atabilirdi.

7. KULLANIM SENARYOLARI

Bu bölüm, sistemin ana iş akışlarını aktör gözünden tanımlar. Senaryolar 5. bölümdeki gereksinimlerin uçtan uca nasıl birleştiğini gösterir.

UC-1: Kayıt olma

Alan	İçerik
Aktör	Ziyaretçi
Ön koşul	Kullanıcının hesabı yoktur.
Ana akış	1. Ziyaretçi kayıt sayfasını açar. 2. Kullanıcı adı, e-posta ve şifre girer; telefon ve adres isteğe bağlıdır. 3. Sistem kuralları doğrular (kullanıcı adı ≥ 3, şifre ≥ 6, geçerli e-posta). 4. Sistem kullanıcı adının ve e-postanın benzersizliğini denetler. 5. Şifre tuzlanıp özetlenir; kullanıcı Customer rolüyle kaydedilir. 6. "Kayıt oldu" olayı loglanır ve kullanıcı giriş sayfasına yönlendirilir.
Alternatif / hata akışları	• Kullanıcı adı veya e-posta zaten kayıtlı $\rightarrow$ işlem reddedilir, açıklayıcı mesaj gösterilir. • Kural ihlali (kısa şifre, geçersiz e-posta) $\rightarrow$ alan bazında hata mesajı. • Dakikada 30 denemeyi aşan IP $\rightarrow$ 429 ve bekleme uyarısı.
Son koşul	Kullanıcı giriş yapabilir durumdadır.

UC-2: Giriş yapma

Alan	İçerik
Aktör	Müşteri / Yönetici
Ön koşul	Kullanıcının kayıtlı ve engellenmemiş bir hesabı vardır.
Ana akış	1. Kullanıcı adı ve şifresini girer. 2. Sistem şifre özetini doğrular. 3. Hesabın engelli olmadığı denetlenir. 4. 120 dakika geçerli JWT üretilir (kullanıcı adı, rol, kullanıcı no claim'leriyle). 5. Jeton istemcide saklanır; gezinme çubuğu role göre yeniden çizilir.
Alternatif / hata akışları	• Hatalı kullanıcı adı/şifre $\rightarrow$ 401; "Başarısız giriş denemesi" loglanır. • Hesap engelli $\rightarrow$ 403 ve yöneticiye başvuru mesajı; olay loglanır.
Son koşul	Kullanıcı oturum açmıştır; yöneticiyse panele erişebilir.

UC-3: Sepete ürün ekleme

Alan	İçerik
Aktör	Müşteri
Ön koşul	Kullanıcı giriş yapmıştır; ürün aktiftir.
Ana akış	1. Müşteri vitrinde veya ürün detayında "Sepete Ekle" der. 2. Sistem müsait adedi hesaplar (BR-2): stoktan başkalarının rezervasyonları ve bekleyen sipariş adetleri düşülür. 3. Talep edilen adet müsaitse satır eklenir veya adet artırılır. 4. AddedAt güncellenerek 30 dakikalık rezervasyon başlatılır. 5. Sepet rozeti güncellenir; işlem loglanır.
Alternatif / hata akışları	• Giriş yapılmamış $\rightarrow$ istek 401 döner, kullanıcı giriş sayfasına yönlendirilir. • Müsait adet yetersiz $\rightarrow$ hata: kalan adet mesajda belirtilir. • Müsait adet sıfır $\rightarrow$ "ürün artık müsait değil" uyarısı.

Alan	İçerik
Son koşul	Ürün sepettedir ve stoktan geçici olarak ayrılmıştır.

UC-4: Sipariş oluşturma (checkout)

Alan	İçerik
Aktör	Müşteri
Ön koşul	Sepette en az bir ürün vardır.
Ana akış	- Müşteri sepet sayfasında teslimat formunu doldurur (alıcı adı, telefon, il, ilçe, açık adres). - Sistem teslimat alanlarının tamamının dolu olduğunu doğrular. - Sepetin boş olmadığı denetlenir. Her kalem için stok müsaitliği yeniden doğrulanır (sepete eklendiğinden beri durum değişmiş olabilir). - Her kalem için birim fiyat, o anki efektif fiyattan dondurulur (BR-7, BR-8). - Teslimat bilgisi sipariş üzerine kopyalanır (BR-9). - Sipariş “Bekliyor” durumunda kaydedilir ve sepet boşaltılır. - Kayıt tamamlandıktan sonra “Siparişiniz alındı” e-postası gönderilir.
Alternatif / hata akışları	- Teslimat bilgisi eksik → işlem reddedilir. - Sepet boş → “Sepetiniz boş” hatası. - Stok yetersiz → hangi üründen kaç adet kaldığı bildirilir, sipariş oluşmaz. - E-posta gönderilemez → sipariş yine de geçerlidir; hata loglanır (BR-23).
Son koşul	Sipariş yönetici onayı beklemektedir; stok henüz düşmemiştir.

UC-5: Siparişi onaylama (kısmi onay dâhil)

Alan	İçerik
Aktör	Yönetici
Ön koşul	Sipariş “Bekliyor” durumundadır.
Ana akış	- Yönetici panelde siparişi açar ve kalemleri inceler. - Tümünü onaylar, tümünü reddeder veya onaylanacak kalemleri tek tek seçer. - Sistem, onaylanacak kalemlerin tamamı için stok yeterliliğini önce denetler, sonra düşer. - Seçilen kalemler Approved, seçilmeyenler Rejected işaretlenir. - En az bir kalem onaylıysa sipariş Approved, değilse Rejected olur (BR-11). - Karar anı ve kararı veren yönetici kaydedilir. - Müşteriye sonucu bildiren e-posta gönderilir; işlem loglanır.
Alternatif / hata akışları	- Sipariş zaten işlenmiş → “Bu sipariş zaten işleme alınmış” hatası. - Stok yetersiz → hangi üründe ne kadar eksik olduğu bildirilir; hiçbir kalem onaylanmaz (kısmi düşme olmaz).
Son koşul	Onaylanan kalemlerin adedi stoktan düşmüştür; müşteri bilgilendirilmiştir.

UC-6: Siparişi iptal etme

Alan	İçerik
Aktör	Müşteri
Ön koşul	Sipariş müşteriye aittir ve “Bekliyor” durumundadır.

Alan	İçerik
Ana akış	1. Müşteri sipariş geçmişinde “İptal Et” der. 2. Sistem siparişin gerçekten bu kullanıcıya ait olduğunu doğrular. 3. Durumun Pending olduğu ve 1 saatlik sürenin dolmadığı sunucuda denetlenir. 4. Sipariş Cancelled olarak işaretlenir; stok değişmez (henüz düşmemiştir). 5. İşlem loglanır.
Alternatif / hata akışları	• Sipariş onaylanmış → “yalnızca Bekliyor durumundaki siparişler iptal edilebilir”. • 1 saat geçmiş → süre dolduğu bildirilir; buton gizli olsa da istek doğrudan atılırsa sunucu reddeder. • Sipariş başkasına ait → “Sipariş bulunamadı”.
Son koşul	Sipariş iptal edilmiştir.

UC-7: Süreli indirim tanımlama

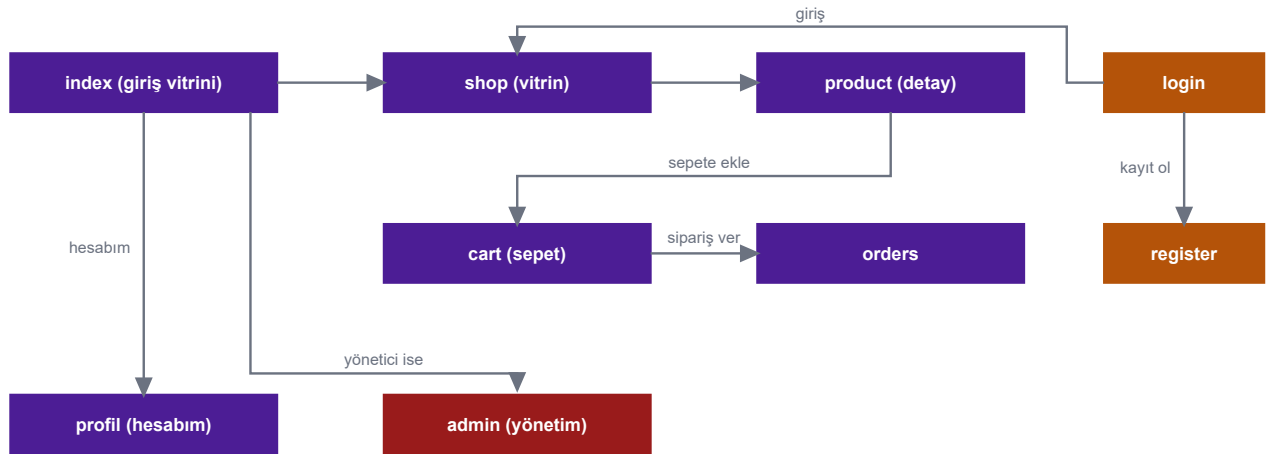
Alan	İçerik
Aktör	Yönetici
Ön koşul	Yönetici giriş yapmıştır.
Ana akış	1. Panelde İndirimler sekmesini açar. 2. Tek ürüne, bir kategorinin tümüne veya seçtiği ürünlere indirim uygular. 3. Yüzde veya doğrudan indirimli fiyat girer; isteğe bağlı başlangıç/bitiş tarihi verir. 4. Sistem indirimli fiyatın liste fiyatından küçük olduğunu doğrular. 5. İşlem, kimin neye ne uyguladığı ayrıntısıyla loglanır. 6. Vitrin ve ürün detayı indirim aktifse eski fiyatı üstü çizili gösterir.
Alternatif / hata akışları	• İndirimli fiyat $\geq$ liste fiyatı → reddedilir. • Tarih aralığı henüz başlamamış → indirim kaydedilir ama aktif olmaz; efektif fiyat liste fiyatı kalır (BR-7).
Son koşul	İndirim planlanmıştır; tarih aralığına girince kendiliğinden uygulanır.

8. KULLANICI ARAYÜZÜ

8.1 Ekran Listesi

Sayfa	Erişim	İçerik
index.html	Herkes	Tanıtım/giriş vitrini: kategori vitrini, öne çıkan ürünler, değer önerileri
shop.html	Herkes	Ana vitrin: canlı arama, kategori ağacı, fiyat aralığı, sıralama, ürün ızgarası, indirim şeridi
product.html	Herkes	Ürün detayı: görsel slider, kategori izi, fiyat/indirim, stok durumu, sepete ekle, kendi alım geçmişin
cart.html	Müşteri	Sepet satırları, adet güncelleme, teslimat formu, sipariş verme
orders.html	Müşteri	Sipariş geçmişi, durum rozetleri, kalan iptal süresi, iptal
profil.html	Müşteri	Hesap bilgileri: ad, e-posta, telefon, adres
login.html / register.html	Ziyaretçi	Giriş ve kayıt formları
admin.html	Yönetici	Yönetim paneli (7 sekme — bkz. 8.3)

8.2 Ekranlar Arası Akış



Mor: müşteriye açık sayfalar • Turuncu: kimlik sayfaları • Kırmızı: yalnızca Admin rolü

"hesabım" ve "yönetici ise" bağlantıları, her sayfada bulunan gezinme çubuğundan erişilir; diyagramda index'ten temsilen çizilmiştir.

8.3 Yönetim Paneli Sekmeleri

Sekme	İşlev
Siparişler	Sipariş listesi (tablo ve il/ilçe görünümü), kalem bazında onay/red, durum ilerletme, müşteri özeti, bekleyen sipariş rozeti
Ürünler	Ürün ekleme/düzenleme, stok girişi, pasife alma/aktifleştirme, kâr sütunu, ürünün sipariş tarihçesi
İndirimler	Kategoriye göre indirim, seçilenlere toplu indirim, ürün bazında tablo üzerinden indirim
Kategoriler	Kategori ekleme/düzenleme, üst-alt kategori ilişkisi, sıralama
Kullanıcılar	Kullanıcı ekleme/düzenleme, engelleme/engel kaldırma, silme, sıralama
Loglar	Tüm denetim kayıtları: kim, ne yaptı, ne zaman

Sekme	İşlev
Analiz	Ciro, kâr, en çok satan ürün, kategori bazında ciro, ürün bazında satış dökümü, dönemsel gelir

8.4 Arayüz İlkeleri

- **Duyarlı (responsive) tasarım:** ızgara ve esnek kutu düzeni kullanılır; dar ekranda çok sütunlu düzenler tek sütuna iner.
- **Geri bildirim:** işlemler sonucunda kısa bildirim (toast) gösterilir; yükleme ve boş durumlar açıkça belirtilir.
- **Güvenli metin basımı:** kullanıcı ve veritabanı kaynaklı tüm metinler ekrana basılmadan önce `escapeHtml` ile kaçışlanır; aksi hâlde ürün adına gömülen HTML çalışırdı (depolanmış XSS).
- **Yetkiye göre çizim:** gezinme çubuğu ve butonlar JWT'den okunan role göre oluşturulur; ancak bu yalnızca kolaylıktır — asıl yetki denetimi sunucudadır.

9. API REFERANSI

Tüm uç noktalar `/api` altındadır ve JSON kullanır. Kimlik, `Authorization: Bearer <JWT>` başlığıyla taşınır. Yetki sütunu: **Herkes** = kimlik gerekmez, **Giriş** = geçerli jeton gerekir, **Admin** = Admin rolü gerekir.

İstek ve yanıt gövdelerinin tam şeması, uygulama geliştirme kipinde çalışırken `/swagger` adresinde yayımlanır.

9.1 Kimlik — `/api/auth`

Metot ve yol	Yetki	Açıklama
POST <code>/auth/register</code>	Herkes	Yeni müşteri kaydı. Hız sınırlı (30/dk/IP).
POST <code>/auth/login</code>	Herkes	Giriş; JWT, kullanıcı adı ve rol döner. Hız sınırlı.

9.2 Katalog — `/api/products`, `/api/categories`

Metot ve yol	Yetki	Açıklama
GET <code>/products</code>	Herkes	Ürün listesi. <code>?search=</code> ada göre arar; <code>?includeInactive=true</code> yalnızca Admin için pasifleri de getirir.
GET <code>/products/{id}</code>	Herkes	Ürün detayı (ek görseller dâhil).
GET <code>/products/{id}/my-history</code>	Giriş	İsteği yapan kullanıcının yalnızca kendi alım geçmişi ve özeti.
POST <code>/products</code>	Admin	Ürün ekler; aynı adda pasif ürün varsa onu canlandırır.
PUT <code>/products/{id}</code>	Admin	Ürünü günceller.
PUT <code>/products/{id}/stock</code>	Admin	Stok girişi.
PUT <code>/products/{id}/discount</code>	Admin	Ürün bazında indirim tanımlar/kaldırır.
PUT <code>/products/category/{categoryId}/discount</code>	Admin	Kategorinin tüm ürünlerine indirim.
PUT <code>/products/discount/bulk</code>	Admin	Seçilen ürünlere toplu indirim/kaldırma.
PUT <code>/products/{id}/activate</code>	Admin	Pasif ürünü yeniden aktifleştirir.
DELETE <code>/products/{id}</code>	Admin	Ürünü pasife alır (soft delete).
GET <code>/categories</code>	Herkes	Kategori ağacı.
POST <code>/categories</code>	Admin	Kategori ekler.
PUT <code>/categories/{id}</code>	Admin	Kategori günceller.
DELETE <code>/categories/{id}</code>	Admin	Kategori siler; alt kategorisi varsa engellenir.

9.3 Sepet ve Sipariş — `/api/cart`, `/api/orders`

Metot ve yol	Yetki	Açıklama
GET <code>/cart</code>	Giriş	Kullanıcının sepeti.
POST <code>/cart</code>	Giriş	Sepete ekler; müsaitlik denetlenir, rezervasyon başlar.
PUT <code>/cart/{id}</code>	Giriş	Adet günceller; rezervasyon süresi yenilenir.
DELETE <code>/cart/{id}</code>	Giriş	Sepet satırını siler.
POST <code>/orders</code>	Giriş	Sepetten sipariş oluşturur; teslimat bilgisi zorunludur.

Metot ve yol	Yetki	Açıklama
GET /orders	Giriş	Kullanıcının kendi sipariş geçmişi; iptal hakkı ve son iptal anı bilgisiyle.
POST /orders/{id}/cancel	Giriş	Kendi siparişini iptal eder (Pending ve ≤ 1 saat).
GET /profile	Giriş	Hesap bilgileri.
PUT /profile	Giriş	Hesap bilgilerini günceller.

9.4 Yönetim — /api/admin

Metot ve yol	Yetki	Açıklama
GET /admin/orders	Admin	Tüm siparişler (müşteri ve teslimat bilgisiyle).
PUT /admin/orders/{id}/approve	Admin	Siparişin tamamını onaylar.
PUT /admin/orders/{id}/reject	Admin	Siparişin tamamını reddeder.
PUT /admin/orders/{id}/decide	Admin	Kalem bazında karar (kısmi onay).
PUT /admin/orders/{id}/status	Admin	Durumu iletir (Kargoda / Teslim Edildi).
DELETE /admin/orders/{id}	Admin	Yalnızca sonuçlanmış siparişi siler.
GET /admin/orders/pending-count	Admin	Bekleyen sipariş sayısı ve son sipariş no'su (yeni sipariş bildirimi için).
GET /admin/products/{id}/orders	Admin	Ürünün tüm sipariş hareketleri ve özeti.
GET /admin/users	Admin	Kullanıcı listesi.
POST /admin/users	Admin	Kullanıcı ekler.
PUT /admin/users/{id}	Admin	Kullanıcıyı günceller; engelleme/engel kaldırma dâhil.
DELETE /admin/users/{id}	Admin	Kullanıcıyı siler; siparişi varsa engellenir.
GET /admin/logs	Admin	Denetim kayıtları.
GET /admin/analytics	Admin	Ciro, kâr, en çok satan, kategori/ürün bazında döküm. ?from=&to= ile dönem.

9.5 Ortak Hata Yanıtları

Kod	Anlamı	Örnek durum
400	İstek geçersiz	Teslimat bilgisi eksik; stok yetersiz; indirimli fiyat liste fiyatından büyük
401	Kimlik doğrulanamadı	Jeton yok, süresi dolmuş, geçersiz; hesap engellenmiş veya silinmiş
403	Yetki yok	Müşterinin yönetim uç noktasına erişmesi; engelli hesapla giriş
404	Bulunamadı	Ürün/sipariş yok ya da başkasına ait
429	Çok fazla istek	Giriş/kayıt uçlarında dakikada 30 denemenin aşılması

Hata gövdesi { "message": " . . . " } biçimindedir ve mesajlar son kullanıcıya gösterilecek şekilde Türkçe yazılmıştır.

10. FONKSİYONEL OLMAYAN GEREKSİNİMLER

10.1 Güvenlik

No	Gereksinim	Gerçeklenme
NFR-1.1	Parolalar geri döndürülemez biçimde saklanmalıdır.	ASP.NET Core PasswordHasher (tuzlu, yinelemeli özet). PasswordHash alanı [JsonIgnore] ile hiçbir yanıtta girmez.
NFR-1.2	Rol, istemci tarafından değiştirilememelidir.	Rol imzalı JWT içindedir; istemci onu yalnızca okur. Yetki her istekte sunucuda denetlenir.
NFR-1.3	Yetkisiz veri sızıntısı olmamalıdır.	Yanıtlar ham entity yerine daraltılmış projeksiyonlarla döner; stok sayısı, maliyet ve indirim planı müşteriye hiç gönderilmez (BR-18).
NFR-1.4	Kaba kuvvet saldırısı engellenmelidir.	Kimlik uçlarında IP başına 30 istek/dakika sabit pencere sınırı. Sınır, NAT arkasındaki meşru kullanıcıları kilitlemeyecek kadar geniş, sözlük saldırısını imkânsız kılacak kadar dardır.
NFR-1.5	Engelleme anında etkili olmalıdır.	Her istekte, jeton imzası doğrulandıktan sonra kullanıcının engel durumu veritabanından okunur (BR-17).
NFR-1.6	Depolanmış XSS önlenmelidir.	İstemcide tüm dinamik metinler escapeHtml ile kaçışlanarak basılır.
NFR-1.7	Gizli bilgiler kaynak kodda bulunmamalıdır.	Bağlantı dizesi, JWT anahtarı ve EmailJS anahtarları User Secrets'ta tutulur; appsettings.json içinde boş bırakılmıştır.
NFR-1.8	İstemciden gönderilen kritik veriye güvenilmemelidir.	İptal süresi, stok yeterliliği ve sahiplik denetimleri sunucuda tekrarlanır; butonun gizli olması yeterli sayılmaz.

10.2 Başarım

- Liste uç noktaları veritabanı tarafında **projeksiyonla** çalışır: yalnızca gereken sütunlar çekilir, ham entity taşınmaz.
- Salt okunur sorgularda AsNoTracking kullanılır; EF Core değişiklik takibi yükü ortadan kalkar.
- EmailService için 10 saniyelik zaman aşımı tanımlıdır; dış servis yanıt vermezse sipariş akışı kilitlenmez.
- HttpClient, soket tükenmesini önlemek için AddHttpClient ile fabrika üzerinden alınır.
- Yönetim panelindeki yeni sipariş bildirimi, tüm listeyi yeniden çekmek yerine yalnızca sayı ve son sipariş no'su döndüren hafif bir uç noktayı yoklar.

10.3 Kullanılabilirlik

- Tüm arayüz metinleri ve hata mesajları Türkçedir ve son kullanıcıya doğrudan gösterilebilecek biçimde yazılmıştır (teknik ayrıntı sızdırmaz).
- Hata mesajları eylem önerir: “stokta yalnızca 3 adet kaldı, sepetindeki adedi azaltmalısın” gibi.
- Sayfalar duyarlıdır; dar ekranda çok sütunlu düzenler tek sütuna iner.
- Kullanıcının iptal hakkı kalan süreyle birlikte gösterilir; hak yoksa nedeni yazılır.

10.4 Sürdürülebilirlik

- Kurallar **tek adreste** tanımlıdır: iptal süresi (OrderService.CancelWindow), rezervasyon süresi (StockService.ReservationWindow), efektif fiyat (Product.EffectivePrice). Hem kural hem arayüz aynı kaynaktan beslenir.
- Şema değişiklikleri migration olarak sürümlenir; el ile SQL çalıştırılmaz.

- Kod yorumları “ne yaptığını” değil “**neden öyle yapıldığını**” anlatır; kararların gerekçesi kodun yanında durur.
- Alınan kararlar, karşılaşılan hatalar ve çıkarılan dersler GELISTIRME-GUNLUGU.md dosyasında kronolojik olarak tutulur.

11. TEST VE DOĞRULAMA

Projede otomatik test paketi bulunmamaktadır; doğrulama, her değişiklikten sonra **çalışan sistem üzerinde uçtan uca** yapılır. Bu bölüm izlenen yöntemi ve kritik senaryoların beklenen sonuçlarını tanımlar.

11.1 Doğrulama Yöntemi

Aşama	Yapılan
1. Derleme	dotnet build — hatasız derlenmelidir.
2. API doğrulaması	Uç nokta gerçek veriyle çağrılır; yanıt gövdesi, durum kodu ve yetki davranışı (jetonlu/jetonsuz) denetlenir.
3. Arayüz doğrulaması	Sayfa tarayıcıda açılır; DOM içeriği, konsol hataları ve yerleşim (masaüstü + dar ekran) kontrol edilir.
4. Yetki sınaması	Aynı uç nokta yetkisiz ve başka kullanıcının jetonuyla denenerek veri sızmadığı doğrulanır.
5. Temizlik	Test için üretilen kullanıcı, sipariş ve ürün kayıtları veritabanından silinir.

11.2 Kritik Test Senaryoları

No	Senaryo	Beklenen sonuç
T-1	Stokta 1 adet varken iki farklı kullanıcı aynı anda sepete 1'er adet ekler.	İkinci kullanıcı "ürün müsait değil" uyarısı alır (BR-2).
T-2	Sepete eklenen ürün 30 dakika bekletilir.	Rezervasyon düşer; ürün başkasına müsait olur, sepette görünmeye devam eder (BR-4).
T-3	Sepete eklendikten sonra stok tükenirken sipariş verilir.	Checkout yeniden denetler ve kalan adedi bildirerek reddeder (FR-5.3).
T-4	Yönetici, 3 kalemlili siparişin 2 kalemini onaylar.	Onaylananların stoğu düşer, üçüncü kalem Rejected, sipariş Approved olur (BR-11).
T-5	Onay sırasında bir kalemin stoğu yetmez.	İşlem tümüyle reddedilir; hiçbir kalemin stoğu düşmez.
T-6	Müşteri, verilışinden 2 saat sonra siparişini iptal etmeye çalışır (istek doğrudan API'ye atılır).	Sunucu süre dolduğu için reddeder; buton gizli olsa da kural sunucuda uygulanır (BR-10).
T-7	Müşteri jetonuyla /api/admin/orders çağrılır.	403 döner.
T-8	Müşteri, başka müşterinin de aldığı bir ürünün detayını açar.	Yalnızca kendi alımlarını görür; başkasının siparişi sızmaz (BR-19).
T-9	Giriş yapmış kullanıcı yönetici tarafından engellenir; eski jetonuyla istek atar.	401 döner (BR-17).
T-10	Müşteri ürün listesini çeker.	Yanıta stok sayısı, maliyet ve indirim planı bulunmaz ; yalnızca inStock vardır (BR-18).
T-11	İndirim, başlangıç tarihi gelecekte olacak şekilde tanımlanır.	Efektif fiyat liste fiyatı kalır; tarih gelince kendiliğinden indirimli olur (BR-7).
T-12	İndirimli üründen sipariş verilir, sonra indirim kaldırılır.	Siparişin birim fiyatı indirimli hâlde kalır (BR-8).
T-13	EmailJS servisi erişilemezken sipariş verilir.	Sipariş oluşur; e-posta hatası loglanır, akış kesilmez (BR-23).
T-14	Siparişi olan kullanıcı silinmeye çalışılır.	Engellenir; yönetici engelleme seçeneğine yönlendirilir (BR-16).
T-15	Alt kategorisi olan kategori silinmeye çalışılır.	Engellenir (BR-15).

No	Senaryo	Beklenen sonuç
T-16	Ürün adına HTML etiketi yazılıp vitrinde görüntülenir.	Metin olarak görünür, çalışmaz (NFR-1.6).

EK-A: KURULUM VE ÇALIŞTIRMA

A.1 Gereksinimler

- .NET 8 SDK
- Microsoft SQL Server (Windows Authentication ile erişim varsayılır)
- Statik dosya sunucusu (örn. npx http-server veya VS Code Live Server)

A.2 Sunucu Kurulumu

#	Adım	Komut / Açıklama
1	Veritabanını oluştur	CREATE DATABASE ETicaretDb;
2	Gizli bilgileri tanımla	dotnet user-secrets init dotnet user-secrets set "ConnectionStrings:DefaultConnection" "Server=localhost; Database=ETicaretDb;Trusted_Connection=True;TrustServerCertificate=True;" dotnet user-secrets set "Jwt:Key" "en-az-32-karakterlik-gizli-anahtar"
3	Şemayı oluştur	dotnet ef database update
4	Rolleri ekle	INSERT INTO Roles (Name) VALUES ('Admin'), ('Customer');
5	Uygulamayı çalıştır	dotnet run — API http://localhost:5113, şema /swagger
6	İlk yöneticiyi oluştur	Önce POST /api/auth/register ile kayıt ol (rol: Customer), sonra veritabanında yükselt: UPDATE Users SET RoleId = 1 WHERE Username = 'kullanici_adin';
7	İstemciyi yayınla	npx http-server frontend -p 5500

Yönetici rolünün yalnızca veritabanından verilebilmesi bilinçli bir karardır: arayüzden rol yükseltme uç noktası bulunmaz.

A.3 Sık Karşılaşılan Sorunlar

Belirti	Neden ve çözüm
dotnet run “Derleme başarısız” diyor; hatada MSB3027 / “used by another process” geçiyor	Kod hatası değildir : uygulama arka planda hâlâ çalışıyor ve .exe dosyasını kilitleyordur. Çalışan süreci kapatın: Get-Process ETicaret.Api Stop-Process -Force
Tarayıcıda “Failed to fetch”	API çalışmıyor ya da adres farklı. Sunucunun 5113'te ayakta olduğunu doğrulayın; geliştirme kipinde CORS tüm kaynaklara açıktır.
Tarihler 3 saat kaymış görünüyor	Tarih “Z” eki olmadan üretilmiş demektir. Tüm tarihler UTC yazılmalıdır (BR-22).
E-posta gitmiyor	EmailJS panelinde Account > Security > “Allow EmailJS API for non-browser applications” açık olmalıdır. Sipariş yine de oluşur; hata loglanır.

EK-B: YAPILANDIRMA

Aşağıdaki ayarlar appsettings.json içinde **boş** bırakılmıştır ve User Secrets üzerinden verilir. Böylece gizli bilgiler sürüm denetimine girmez.

Anahtar	Açıklama	Varsayılan
ConnectionStrings:DefaultConnection	SQL Server bağlantı dizesi	— (gizli)
Jwt:Key	İmzalama anahtarı; en az 32 karakter	— (gizli)
Jwt:Issuer	Jetonu üreten taraf	ETicaretApi
Jwt:Audience	Jetonun hedef kitlesi	ETicaretClient
Jwt:ExpiryMinutes	Jeton geçerlilik süresi (dakika)	120
EmailJS:ServiceId / TemplateId / PublicKey / PrivateKey	E-posta servisi kimlik bilgileri	— (gizli)
EmailJS:ApiUrl	Test amaçlı farklı bir uç nokta; verilmezse EmailJS'in kendi adresi kullanılır	(isteğe bağlı)

B.1 Sabitler

Aşağıdaki iş kuralı sabitleri koda gömülüdür ve tek bir yerde tanımlıdır:

Sabit	Değer	Tanım yeri
Sepet rezervasyon süresi	30 dakika	StockService.ReservationWindow
Sipariş iptal süresi	1 saat	OrderService.CancelWindow
Jeton ömrü	120 dakika	Jwt:ExpiryMinutes
Kimlik hız sınırı	30 istek / dakika / IP	Program.cs – AuthLimit
En kısa kullanıcı adı	3 karakter	AuthService.MinUsernameLength
En kısa şifre	6 karakter	AuthService.MinPasswordLength
E-posta zaman aşımı	10 saniye	EmailService

Bu belge, uygulamanın 17 Temmuz 2026 tarihli kod tabanı incelenerek hazırlanmıştır.